

RESERVE BANK OF INDIA

DEPARTMENT OF INFORMATION TECHNOLOGY, MUMBAI

RBI/2024-25/125 DoS.CO.CSITE.REC.19/31.01.015/2024-25

September 18, 2024

Master Direction on Information Technology Governance and Cyber Resilience

1. Chief Information Security Officer (CISO): Every Regulated Entity shall appoint a qualified, full-time CISO who shall be an officer in the rank of General Manager or equivalent. The CISO shall report directly to the Executive Director or to the Board Information Technology Committee, and shall have independent authority over cybersecurity posture and incident response.
2. Cyber Incident Reporting Timelines: All cybersecurity incidents of severity High or Critical (including ransomware infections, unauthorized intrusions, credential leaks, and core system outages) must be reported to the Reserve Bank's Cyber Security Operations Centre (CSOC) within six hours of detection. A detailed Root Cause Analysis (RCA) report must be submitted within 21 calendar days.
3. Security Operations Centre (SOC): Regulated Entities must establish and maintain an in-house or managed SOC operational on a continuous 24x7x365 basis. The SOC must ingest logs from all core applications, firewalls, and Active Directory servers, retaining tamper-evident audit logs for a minimum duration of one year online and three years in cold archive.

4. Multi-Factor Authentication (MFA): Multi-factor authentication is mandatory for all administrative access, database logins, VPN connections, and remote access to critical infrastructure. SMS-only OTP is not considered adequate for privileged administrative sessions; hardware security keys or authenticator app tokens must be enforced.
5. Vulnerability Assessment and Penetration Testing (VAPT): Comprehensive VAPT of all Internet-facing applications and core systems must be conducted at least once every six months by CERT-In empanelled auditors. Critical vulnerabilities identified must be remediated within 15 calendar days of receipt of the audit report.
6. Board Information Technology Committee: The Board of Directors of every bank shall constitute an IT Committee comprising one independent director with demonstrated expertise in computer science or enterprise IT infrastructure.

7. Cyber Crisis Management Plan (CCMP): Every bank shall formulate a comprehensive CCMP approved by the Board. Tabletop crisis simulation exercises and red-teaming drills must be conducted at least once annually involving senior executive management.
8. Patch Management Timelines: High and critical security patches released by original equipment manufacturers (OEMs) must be installed and deployed within seven calendar days of release. Zero-day vulnerability mitigations must be activated within 24 hours.
9. Data Loss Prevention (DLP): Endpoint and network DLP solutions must be implemented to prevent unauthorized exfiltration of customer data, personal identifiers, and financial records through USB storage, personal email, or cloud file-sharing services.

10. Critical Information Infrastructure (CII): Systems processing high-value payment transactions, RTGS/NEFT interfaces, and core banking transaction engines shall be declared as Critical Information Infrastructure under Section 70 of the IT Act, 2000.
11. Secure Software Development Life Cycle (SSDLC): All in-house applications and third-party software customizations must adhere to SSDLC guidelines, including static application security testing (SAST) and dynamic analysis (DAST) prior to production deployment.
12. Third-Party Vendor Security: Contracts with technology vendors must include clauses granting the Reserve Bank the right to audit vendor infrastructure supporting the bank's outsourced operations.

Yours faithfully,

(P. V. Narayanan)

Chief General Manager-in-Charge